

CYBERSECURITY & ETHICAL HACKING

INTERNSHIP REPORT

Week 4 — Black-Box Security Assessment

Mediroza General Hospital — Authorized Penetration Test

Name	Daniyal Ahmed
Intern ID	NW-83-4UP
Program / Batch	B083 – Networkwalks
Course	Cybersecurity & Ethical Hacking
Week / Module	Week 4 — Black-Box Security Assessment
Target	https://medirozahospital.com (Authorized training target)
Assessment Type	Black-box / Blind security assessment

1. Objective

The objective of this Week 4 practical was to perform a comprehensive black-box security assessment against the authorized training target Mediroza General Hospital (<https://medirozahospital.com>). Operating under a black-box methodology means the assessment was executed with no prior visibility into the application’s source code, architecture, or internal network — accurately emulating the perspective of a real-world external threat actor.

The assessment lifecycle covered full end-to-end penetration testing: information gathering, vulnerability discovery, active exploitation, post-exploitation data exfiltration, and professional reporting with risk ratings and remediation guidance.

2. Scope & Rules of Engagement

All testing was strictly confined to the authorized scope (<https://medirozahospital.com>) and complied with the established Rules of Engagement:

- Denial of Service (DoS) and destructive methodologies were strictly prohibited.
- Social engineering, phishing, and physical security testing were excluded.
- All discovered vulnerabilities were documented for the authorizing entity.
- Exfiltrated data was used solely for proof-of-concept validation and treated as sensitive training material.

3. Tools & Techniques

Tool	Application
curl	HTTP header inspection, directory probing, and raw data retrieval
WhatWeb	Web technology fingerprinting and host IP identification
THC-Hydra	Parallelized login cracking against authentication portals
sqlmap	Automated detection and validation of SQL injection flaws
qpdf	Decryption of password-protected PDF patient reports
ExifTool	Forensic metadata inspection of extracted documents
Burp Suite / DevTools	HTTP interception, cookie analysis, and form behavior auditing

Techniques applied included directory enumeration, SQL injection (error-based), credential brute-forcing, session establishment, sensitive data exposure, and passive reconnaissance via HTTP headers, robots.txt, and sitemap analysis.

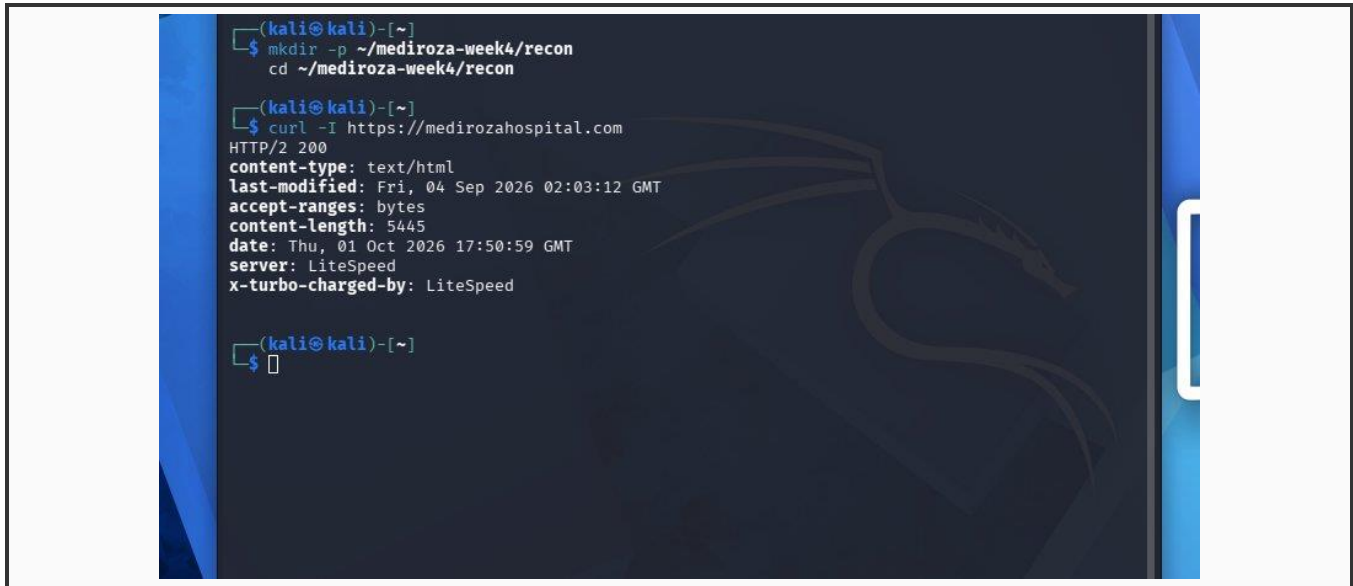
4. Reconnaissance & Information Gathering

This phase focused on active and passive intelligence gathering to map the target's attack surface and isolate viable entry points prior to exploitation.

4.1 HTTP Header Analysis & Banner Grabbing

Initial probing of the target's HTTP response headers was conducted using curl against the /staff/ endpoint.

Figure 1 — curl HTTP header analysis



```
(kali@kali)-[~]
└─$ mkdir -p ~/mediroza-week4/recon
    cd ~/mediroza-week4/recon

(kali@kali)-[~]
└─$ curl -I https://medirozahospital.com
HTTP/2 200
content-type: text/html
last-modified: Fri, 04 Sep 2026 02:03:12 GMT
accept-ranges: bytes
content-length: 5445
date: Thu, 01 Oct 2026 17:50:59 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

(kali@kali)-[~]
└─$
```

Figure 1: curl -i output showing LiteSpeed server headers

Key observations: Server and x-turbo-charged-by both disclosed LiteSpeed, revealing the underlying web server architecture and caching layer.

4.2 Web Technology Fingerprinting (WhatWeb)

WhatWeb was used to fingerprint the application stack and identify the host IP address.

Figure 2 — WhatWeb fingerprinting results



```
(kali@kali)-[~]
└─$ whatweb https://medirozahospital.com
https://medirozahospital.com [403 Forbidden] Country[UNITED STATES][US], HTML5, HTTPServer[LiteSpeed], IP[199.188.201.16], LiteSpeed, PoweredBy[LiteSpeed], Title[403 Forbidden], UncommonHeaders[x-turbo-charged-by]

(kali@kali)-[~]
└─$
```

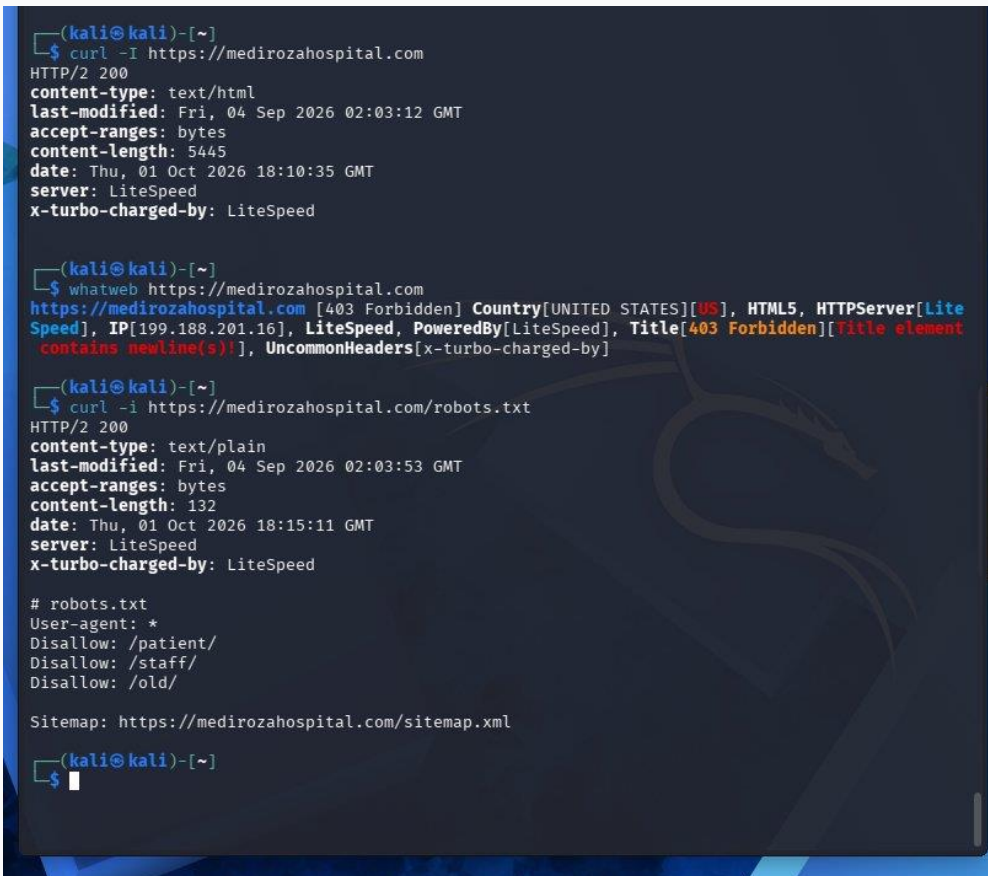
Figure 2: WhatWeb output — LiteSpeed, HTML5, host IP 199.188.201.16

4.3 robots.txt & Directory Discovery

The robots.txt file exposed three restricted navigational paths that search engines are instructed to ignore — but which provide attackers with a clear roadmap:

- Disallow: /patient/
- Disallow: /staff/
- Disallow: /old/

Figure 3 — robots.txt contents



```
(kali@kali)-[~]
$ curl -I https://medirozahospital.com
HTTP/2 200
content-type: text/html
last-modified: Fri, 04 Sep 2026 02:03:12 GMT
accept-ranges: bytes
content-length: 5445
date: Thu, 01 Oct 2026 18:10:35 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

(kali@kali)-[~]
$ whatweb https://medirozahospital.com
https://medirozahospital.com [403 Forbidden] Country[UNITED STATES][US], HTML5, HTTPServer[LiteSpeed], IP[199.188.201.16], LiteSpeed, PoweredBy[LiteSpeed], Title[403 Forbidden][Title element contains newline(s)!], UncommonHeaders[x-turbo-charged-by]

(kali@kali)-[~]
$ curl -i https://medirozahospital.com/robots.txt
HTTP/2 200
content-type: text/plain
last-modified: Fri, 04 Sep 2026 02:03:53 GMT
accept-ranges: bytes
content-length: 132
date: Thu, 01 Oct 2026 18:15:11 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml

(kali@kali)-[~]
$
```

Figure 3: robots.txt revealing restricted /patient/, /staff/, and /old/ paths

4.4 Insecure Directory Listing

Probing the discovered directories confirmed that directory listing was enabled, allowing unauthenticated browsing of internal file structures.

Figure 4 — Directory listing for /staff/ and /old/

```
(kali@kali)-[~]
$ curl -i https://medirozahospital.com/staff/
HTTP/2 200
content-type: text/html; charset=UTF-8
content-length: 1568
date: Thu, 01 Oct 2026 18:22:35 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

<!DOCTYPE html><html><head><meta http-equiv="Content-type" content="text/html; charset=UTF-8" /
><meta name="viewport" content="width=device-width, initial-scale=1.0" /><link rel="stylesheet"
href="/_autoindex/assets/css/autoindex.css" /><script src="/_autoindex/assets/js/tablesort.js"
></script><script src="/_autoindex/assets/js/tablesort.number.js"></script><title>Index of /sta
ff/</title><style>@media (prefers-color-scheme:dark){body{background-color:#000!important}}</st
yle></head><body><div class="content"><h1 style="color: #555;">Index of /staff/</h1>
<div id="table-list"><table id="table-content"><thead class="t-header"><tr><th class="colname"
aria-sort="ascending"><a class="name" href="?ND" onclick="return false">Name</a></th><th clas
s="colname" data-sort-method="number"><a href="?MA" onclick="return false">Last Modified</a><
/th><th class="colname" data-sort-method="number"><a href="?SA" onclick="return false">Size</
a></th></tr></thead>
<tr data-sort-method="none"><td><a href="/">Parent Directory</a></td><td></td><td></td></tr>
<tr><td data-sort="login.php"><a href="/staff/login.php">login.php</a></td><td data-sort="1788487502">2026-09-04 02
:05</td><td data-sort="2222">3k</td></tr>
</table></div>
<address>Proudly Served by LiteSpeed Web Server at medirozahospital.com Port 443</address></div>
<script>new Tablesort(document.getElementById('table-content'));</script></body></html>

(kali@kali)-[~]
$ curl -i https://medirozahospital.com/old/
HTTP/2 200
content-type: text/html; charset=UTF-8
content-length: 1610
date: Thu, 01 Oct 2026 18:22:54 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

<!DOCTYPE html><html><head><meta http-equiv="Content-type" content="text/html; charset=UTF-8" /
><meta name="viewport" content="width=device-width, initial-scale=1.0" /><link rel="stylesheet"
href="/_autoindex/assets/css/autoindex.css" /><script src="/_autoindex/assets/js/tablesort.js"
></script><script src="/_autoindex/assets/js/tablesort.number.js"></script><title>Index of /old
/</title><style>@media (prefers-color-scheme:dark){body{background-color:#000!important}}</styl
e></head><body><div class="content"><h1 style="color: #555;">Index of /old/</h1>
<div id="table-list"><table id="table-content"><thead class="t-header"><tr><th class="colname"
aria-sort="ascending"><a class="name" href="?ND" onclick="return false">Name</a></th><th clas
s="colname" data-sort-method="number"><a href="?MA" onclick="return false">Last Modified</a><
/th><th class="colname" data-sort-method="number"><a href="?SA" onclick="return false">Size</
a></th></tr></thead>
```

Figure 4: Directory listing enabled on /staff/ and /old/

Figure 5 — Directory listing for /patient/

```
(kali@kali)-[~]
$ curl -i https://medirozahospital.com/patient/
HTTP/2 200
content-type: text/html; charset=UTF-8
content-length: 3419
date: Thu, 01 Oct 2026 18:22:20 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

<!DOCTYPE html><html><head><meta http-equiv="Content-type" content="text/html; charset=UTF-8" /
><meta name="viewport" content="width=device-width, initial-scale=1.0" /><link rel="stylesheet"
href="/_autoindex/assets/css/autoindex.css" /><script src="/_autoindex/assets/js/tablesort.js"
></script><script src="/_autoindex/assets/js/tablesort.number.js"></script><title>Index of /pat
ient/</title><style>@media (prefers-color-scheme:dark){body{background-color:#000!important}}</st
yle></head><body><div class="content"><h1 style="color: #555;">Index of /patient/</h1>
<div id="table-filter"><input type="text" name="keyword" id="filter-keyword" placeholder="Filt
er Name"></div>
<div id="table-list"><table id="table-content"><thead class="t-header"><tr><th class="colname"
aria-sort="ascending"><a class="name" href="?ND" onclick="return false">Name</a></th><th clas
s="colname" data-sort-method="number"><a href="?MA" onclick="return false">Last Modified</a><
/th><th class="colname" data-sort-method="number"><a href="?SA" onclick="return false">Size</
a></th></tr></thead>
<tr data-sort-method="none"><td><a href="/">Parent Directory</a></td><td></td><td></td></tr>
<tr><td data-sort="reports"><a href="/patient/reports/">reports</a></td><td data-sort="211687433">2026-09-04
02:03</td><td data-sort="1"></td></tr>
<tr><td data-sort="download.php"><a href="/patient/download.php">download.php</a></td><td data-sort="1788487491">20
26-09-04 02:04</td><td data-sort="715">1k</td></tr>
<tr><td data-sort="error_log"><a href="/patient/error_log">error_log</a></td><td data-sort="1789190742">2026-09-12 05:25<
/td><td data-sort="247865">243k</td></tr>
<tr><td data-sort="login.php"><a href="/patient/login.php">login.php</a></td><td data-sort="1788532095">2026-09-04
14:28</td><td data-sort="3742">4k</td></tr>
<tr><td data-sort="logout.php"><a href="/patient/logout.php">logout.php</a></td><td data-sort="1788487491">2026-09-
04 02:04</td><td data-sort="122">1k</td></tr>
<tr><td data-sort="portal.php"><a href="/patient/portal.php">portal.php</a></td><td data-sort="1788487484">2026-09-
04 02:04</td><td data-sort="2275">3k</td></tr>
</table></div>
<address>Proudly Served by LiteSpeed Web Server at medirozahospital.com Port 443</address></div>
<script>
new Tablesort(document.getElementById('table-content'));
var keywordInput = document.getElementById('filter-keyword');
document.addEventListener('keyup', filterTable);
```

Figure 5: Directory listing on /patient/ exposing login.php, portal.php, download.php, reports/

Exposed assets included login.php under /staff/ and /patient/, the SQL backup mediroza_db_backup_2019.sql under /old/, and patient portal scripts under /patient/.

4.5 Unprotected SQL Backup Discovery

Within /old/, a complete MySQL database backup (mediroza_db_backup_2019.sql) was publicly accessible with zero access controls. Offline analysis confirmed tables for staff and shareholders containing employee PII, national IDs, exact monthly salaries, and shareholder equity data.

Critical Finding: A highly sensitive SQL dump containing executive financials, employee PII, and corporate shareholder equity was publicly hosted without authentication.

5. Active Exploitation

5.1 SQL Injection — Patient Portal Login

Target endpoint: <https://medirozahospital.com/patient/login.php>. A single quote injected into the username field produced a verbose MySQL syntax error, confirming both SQL injection and sensitive error disclosure.

Figure 6 — MySQL error disclosure confirming SQLi

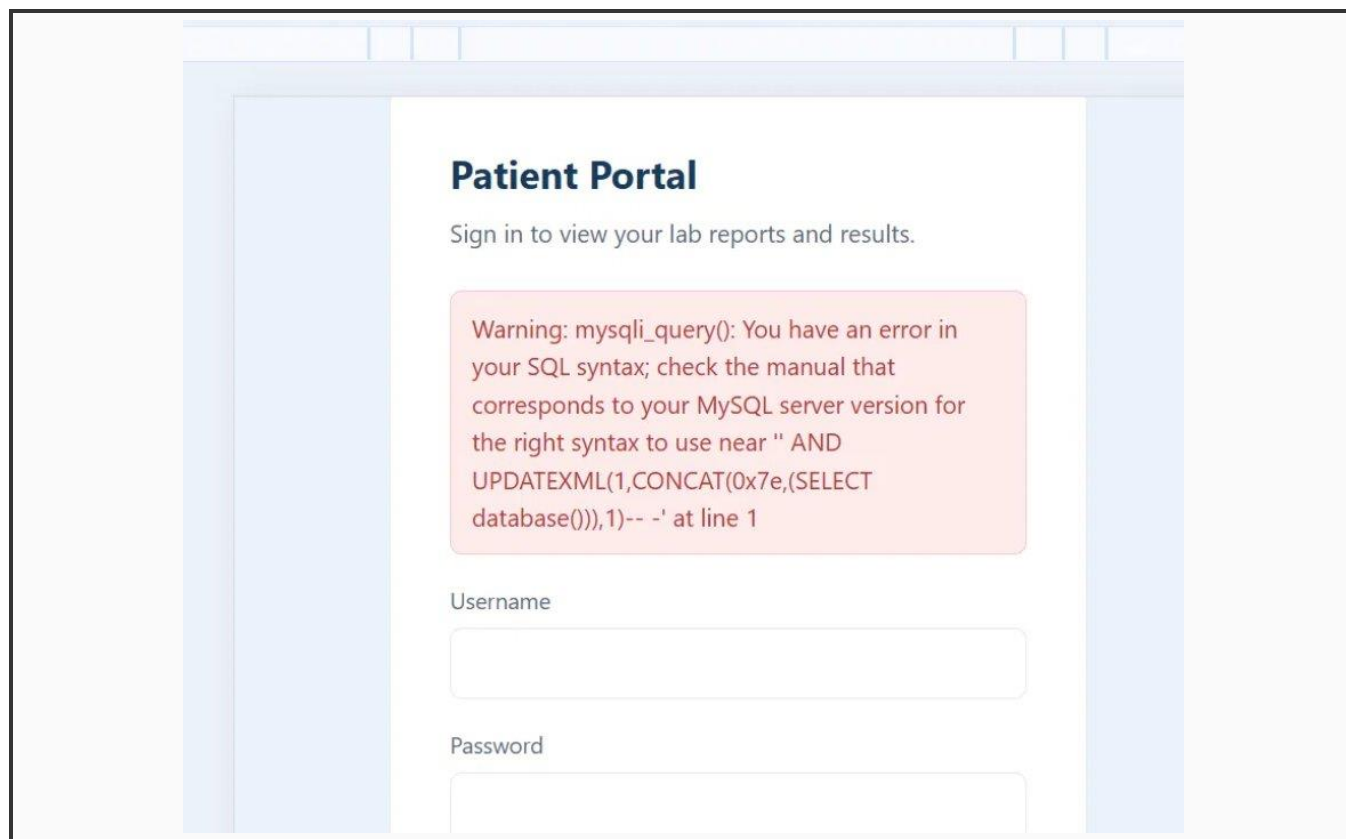


Figure 6: MySQL syntax error returned to the browser — confirms SQLi and error disclosure

5.2 Username Enumeration

Differential error responses allowed precise username enumeration: “Username not found” for invalid accounts versus “Incorrect password” for valid ones. The account “admin” was confirmed to exist.

Figure 7 — Username enumeration via error discrepancy

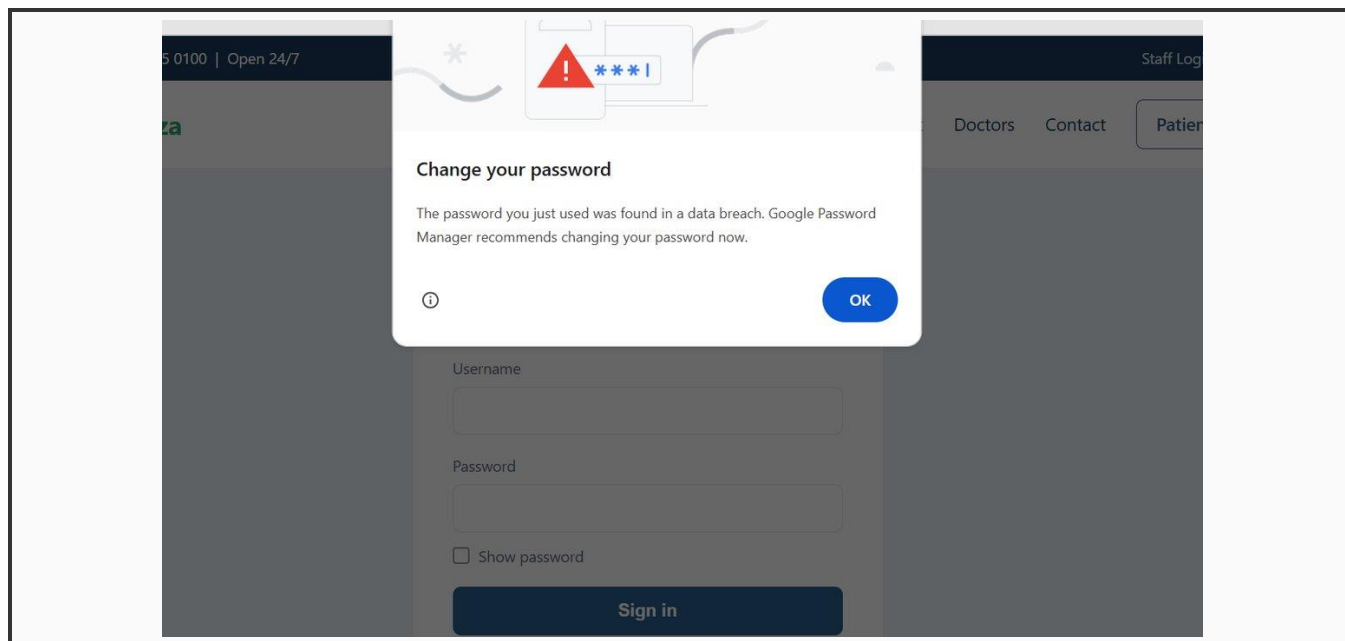


Figure 7: Differential error messages enabling username enumeration

5.3 Credential Brute-Forcing (Hydra)

A targeted dictionary attack was executed with Hydra against the admin account using the fasttrack.txt wordlist, single-threaded with a 5-second delay for stealth.

Figure 8 — Hydra successful crack

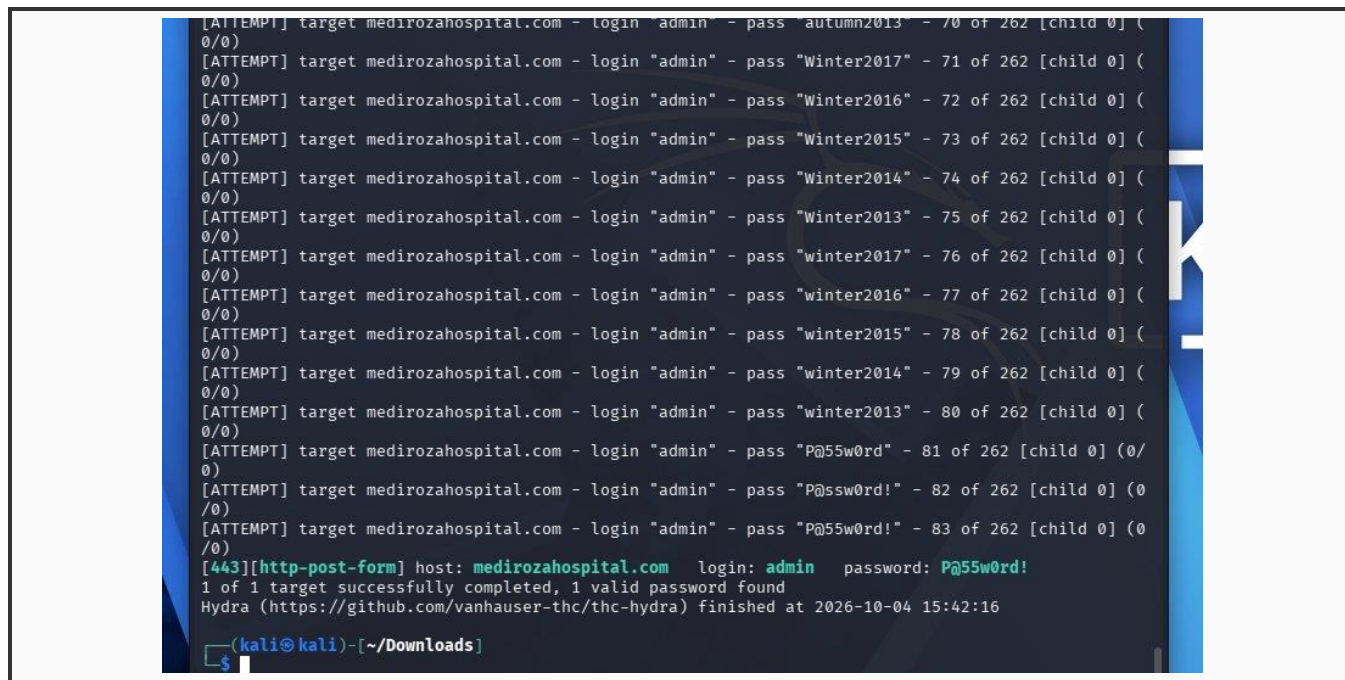


Figure 8: Hydra result — admin / Spring2017 cracked

Compromised credentials: admin / Spring2017.

5.4 Session Establishment

Using the cracked credentials, an authenticated session was established in the restricted patient portal at /patient/portal.php.

Figure 9 — Authenticated patient portal access

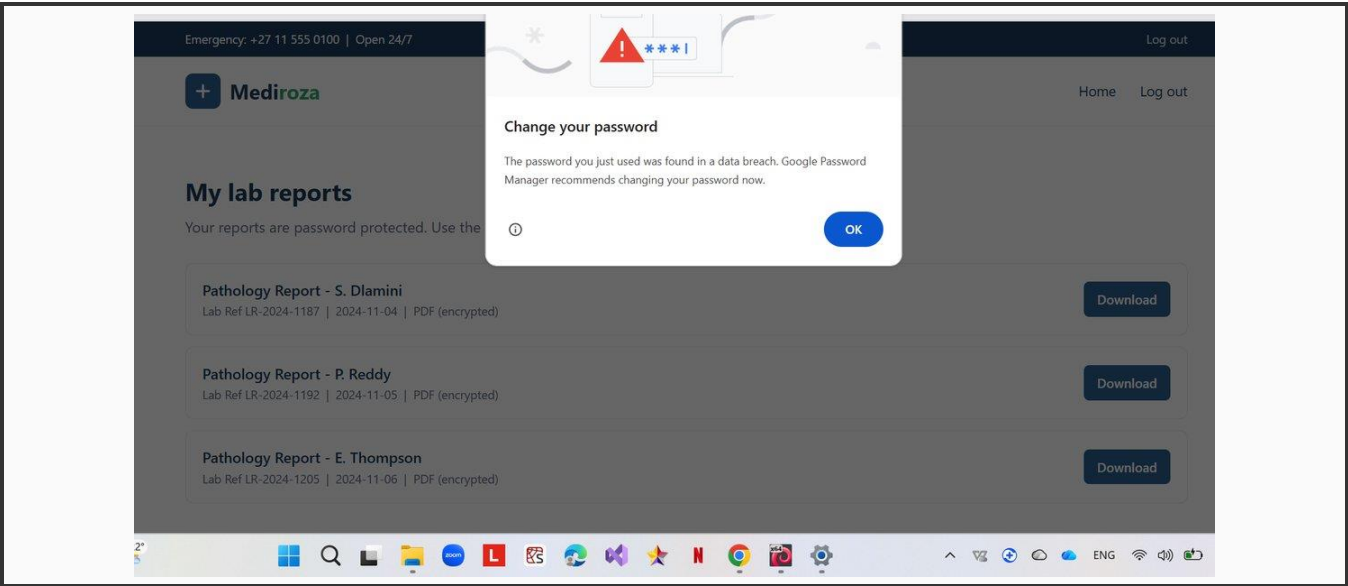


Figure 9: Successful login to the patient portal as admin

6. Post-Exploitation & Data Exfiltration

6.1 Patient Report Downloads

Authenticated access enabled download of password-protected patient pathology reports via /patient/download.php.

Figure 10 — Downloaded password-protected PDF reports

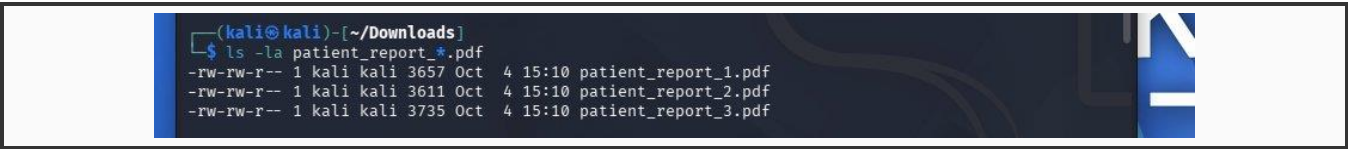


Figure 10: Patient report PDFs downloaded (password-protected)

6.2 PDF Password Recovery & Decryption

Document hashes were subjected to dictionary attacks. All three medical records used weak passwords:

Report File	Patient	Recovered Password
patient_report_1.pdf	S. Dlamini	123456
patient_report_2.pdf	P. Reddy	password
patient_report_3.pdf	E. Thompson	!@#\$\$%^&

qpdf was used to decrypt the reports with the recovered passwords.

Figure 11 — Decrypted patient reports

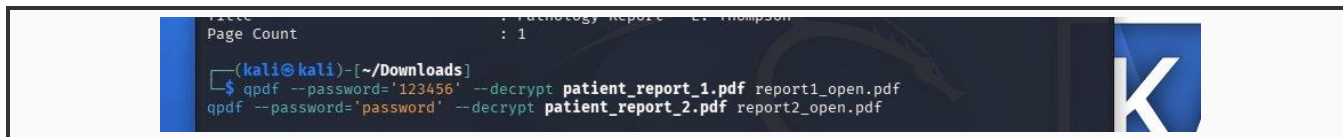


Figure 11: PDF reports successfully decrypted with qpdf

6.3 Staff Payroll & Shareholder Exposure

Analysis of the unprotected SQL dump revealed complete employee records and shareholder equity data:

Employee	Role	Monthly Salary (ZAR)
Dr. Johan van der Merwe	Medical Director	R 160,000
Sarah Botha	Chief Financial Officer	R 152,000
Dr. Rajesh Naidoo	Chief Pathologist	R 138,000
Dr. Anita Naicker	Consultant Cardiologist	R 132,000
Dr. Ahmed Kara	Consultant Physician	R 128,000
Dr. Yusuf Cassim	Senior Registrar	R 74,000

6.4 PDF Metadata Forensics (ExifTool)

Forensic metadata analysis on a decrypted report exposed internal usernames, CMS version, and a comment that directly leaked the path to the unprotected SQL backup.

Figure 12 — ExifTool metadata extraction



Figure 12: ExifTool output revealing Author, Comments, Creator, and Title metadata

Critical chain: Exposed PDF metadata → Unprotected /old/ directory → SQL backup exfiltration → Mass exposure of staff payroll and shareholder data.

7. Findings Summary & Risk Ratings

#	Finding	Impact	Risk
1	Unprotected SQL database backup	Full staff PII, salaries, and shareholder equity exposed	Critical
2	SQL Injection on patient login	Authentication bypass and database interaction	Critical
3	Weak credentials (admin/Spring2017)	Full access to patient portal and reports	High
4	Directory listing enabled	Internal structure and sensitive files discoverable	High
5	Weak PDF passwords on medical records	Protected health information easily decrypted	High
6	Sensitive metadata in PDFs	Internal paths and usernames leaked	Medium
7	Verbose error messages / username enum	Aids targeted attacks and reconnaissance	Medium
8	Server/CMS version disclosure	Aids exploit targeting	Low

8. Remediation Recommendations

- Immediately remove or access-restrict the /old/ directory and any public database backups.
- Implement parameterized queries / prepared statements to eliminate SQL injection.
- Enforce strong password policy and multi-factor authentication on all portals.
- Disable directory listing on the web server (LiteSpeed / Apache configuration).
- Use strong, unique encryption passwords (or better, proper access control) for patient documents; strip sensitive metadata before distribution.
- Suppress verbose database errors in production; return generic error messages only.
- Remove or obfuscate server and CMS version headers and HTML generator meta tags.

- Conduct regular authorized penetration tests and security reviews of healthcare systems handling PII and PHI.

9. Conclusion

This Week 4 black-box assessment demonstrated how a chain of seemingly isolated weaknesses — directory listing, an unprotected SQL backup, SQL injection, weak credentials, and poor PDF protection — can cascade into full compromise of a healthcare application. Sensitive patient records, staff payroll, and shareholder data were all accessible to an external attacker operating without prior internal knowledge.

The exercise reinforces that healthcare systems require rigorous access controls, secure coding practices, and continuous security validation. All activities were performed strictly within the authorized training scope for educational purposes.

10. Disclaimer

All offensive techniques and methodologies documented in this report were performed against an authorized training target provided for the Networkwalks Cybersecurity Internship. No unauthorized systems were accessed. Executing these attacks against any system or network without prior explicit, written authorization is a criminal offense under applicable cyber legislation.

— *End of Report* —